

 **Servicio 01-B: Diagnóstico de Exposición Externa y Evaluación de Superficie de Ataque (Infraestructura Física/On-Premise).**

 **El Problema a Solucionar:** Muchas empresas medianas (como hoteles o comercios locales) apuntan sus dominios comerciales directamente a las IPs públicas de sus servidores locales (On-Premise) sin una capa intermedia de protección (WAF/Proxy Reverso). Esto deja al descubierto no solo la aplicación web, sino sistemas críticos como bases de datos, servidores de archivos (FTP) y servicios de terminales de administración, exponiendo su infraestructura directamente a escaneos automatizados en internet, la cual en ocasiones trabaja con software heredado o sin parches de seguridad.

 **Metodología Aplicada:** Auditoría externa pasiva basada en fuentes abiertas (OSINT) e identificación de huellas digitales (Banner Grabbing):

- 1. Análisis de Enrutamiento:** Verificación de resolución directa DNS y registros PTR para identificar el ISP y la ubicación del servidor de origen.
- 2. Identificación de Capas de Red y Puertos:** Mapeo pasivo de servicios expuestos utilizando motores de búsqueda de infraestructura conectada (Shodan).
- 3. Inspección de Banners y Cabeceras:** Análisis de respuestas HTTP/FTP/SGBD para determinar versiones exactas de sistemas operativos y frameworks.
- 4. Mapeo de Nomenclatura Interna:** Descubrimiento de subdominios relacionados que revelen la estructura y topología de la red interna de la organización.

Resultados Obtenidos (Caso de Estudio Muestra)

Objetivo Evaluado: Infraestructura de servidor único de una entidad del sector hospitalidad (hotel.mx).

Calificación de Exposición Digital: 76/100 (Riesgo Alto) correspondiente al promedio de las valoraciones individuales de las condiciones inseguras detectadas.

Hallazgos Críticos: Exposición directa a internet de la IP pública sin controles perimetrales proxy o WAF aparentes. - Uso de servidor web Microsoft IIS 7.5 y PHP 5.4.36, tecnologías en estado de Fin de Ciclo de Vida (EOL), acumulando vulnerabilidades públicas sin parches disponibles. - Exposición del puerto de Base de Datos (MySQL 5.6.26) y del servicio FileZilla Server 0.9.41 Beta (versión obsoleta vinculada a librerías OpenSSL vulnerables a incidentes como Heartbleed). - Fuga de información de la red interna a través del subdominio de correo detectado (HDGDLMAIL01).

 **Herramientas Utilizadas:** Shodan (Motor de búsqueda de dispositivos conectados a internet). curl (Análisis de cabeceras de respuesta HTTP). Dig / Nslookup (Análisis de resolución de nombres y DNS reverso). Repositorios de vulnerabilidades públicas (CVE/NVD) para correlación de versiones EOL.

Lecciones aprendidas: En ocasiones se mantienen activas infraestructuras antiguas ya que funcionan correctamente, sin embargo, configuraciones y tecnologías que eran seguras y efectivas hace años, pueden resultar ser vulnerables con el tiempo, especialmente al no contar con soporte activo para nuevas amenazas las cuales aparecen todos los días.